ACTIVE DIRECTORY SECURITY

HOMELAB PORTFOLIO

Windows Server 2025 | Splunk SIEM | BloodHound CE | Sysmon

Arturs Kaufmanis

Cybersecurity Professional | HyperionDev Bootcamp Graduate

Manchester Metropolitan University

2026

1. Executive Summary

This portfolio documents the design, implementation, and security hardening of a comprehensive Active Directory homelab environment. The project demonstrates enterprise-level cybersecurity skills including SIEM integration, attack path analysis, identity management, and security monitoring.

The lab was built to demonstrate practical competency in:

- Active Directory deployment and security hardening
- SIEM implementation using Splunk Enterprise
- Endpoint detection using Sysmon and Splunk Add-on for Sysmon
- Attack path visualization using BloodHound Community Edition
- Local Administrator Password Solution (LAPS) deployment
- PingCastle security assessment scoring
- WSL2, Docker, and containerized security tools

1.1 Lab Environment Summary

Component	Specification
Domain Controller	Windows Server 2025 (Build 26100)
Domain Name	ADForest.local
Forest/Domain Functional Level	Windows Server 2016
DC Hostname	WIN-ESVD1CAD1FJ
RAM	24GB
SIEM	Splunk Enterprise 10.2 (Free)
EDR	Sysmon v15.15 with SwiftOnSecurity config
Attack Path Tool	BloodHound Community Edition (Docker)
Container Platform	Docker Engine on WSL2 Ubuntu 24.04
Security Assessment	PingCastle v3.x

1.2 PingCastle Score Progression

Session	Global Score	Privileged	Stale Objects	Anomaly	Trust
Baseline	60	40	31	60	0

Session	Global Score	Privileged	Stale Objects	Anomaly	Trust
Session 1 - Password/NTLMv1 fixes	50	0	21	50	0
Session 2 - Backup/Audit fixes	35	0	21	35	0
Session 3 - LAPS/AES/SecAdmin	21	20	21	20	0
Final - Schema Admins/Backup	20	20	20	20	0

> *67% improvement from baseline score of 60 to final score of 20. Remaining findings are lab limitations (single DC, BreakGlass used within 60 days).*

2. Phase 1 - Active Directory Deployment & Baseline

2.1 Initial Setup

Windows Server 2025 was installed and configured as a Domain Controller for the ADForest.local domain. The following roles were installed:

- Active Directory Domain Services (AD DS)
- DNS Server
- Group Policy Management

2.2 Baseline PingCastle Assessment

PingCastle was used to establish a security baseline. Initial scan revealed a global score of 60 with multiple critical findings:

Finding	Points	Description
S-OldNtlm	15	NTLMv1 authentication enabled
A-LAPS-Not-Installed	15	Local Admin Password Solution not deployed
A-AuditDC	10	Insufficient audit policy on Domain Controllers
MachineAccountQuota	10	Default quota allows any user to join computers to domain
Schema Admins not empty	10	Administrator in Schema Admins group
A-HardenedPaths	5	Hardened UNC paths not configured
A-NotEnoughDC	5	Single Domain Controller - no redundancy
S-DC-SubnetMissing	5	DC subnets not declared in AD Sites and Services
S-PwdNeverExpires	1	Accounts with non-expiring passwords

3. Phase 2 - Security Hardening

3.1 Password Policy

Default password policy was strengthened to meet enterprise standards:

```
Set-ADDefaultDomainPasswordPolicy -Identity 'ADForest.local' -MinPasswordLength
12
```

Result: Minimum password length increased from 7 to 12 characters.

3.2 AD Recycle Bin

Enabled AD Recycle Bin to allow recovery of accidentally deleted objects:

```
Enable-ADOptionalFeature -Identity 'Recycle Bin Feature' -Scope
ForestOrConfigurationSet -Target 'ADForest.local' -Confirm:$false
```

Result: Deleted AD objects can now be recovered within 180 days (tombstone lifetime).

3.3 MachineAccountQuota

By default, any domain user can join up to 10 computers to the domain. This was disabled to prevent unauthorized domain joins:

```
Set-ADDomain -Identity 'ADForest.local' -Replace @{'ms-DS-
MachineAccountQuota'='0'}
```

Result: Only administrators can now join computers to the domain, preventing unauthorized device registration.

3.4 Schema Admins Cleanup

The built-in Administrator account was removed from Schema Admins. Schema Admins is one of the most powerful groups in AD - members can make irreversible forest-wide schema modifications:

```
Remove-ADGroupMember -Identity 'Schema Admins' -Members 'Administrator' -
Confirm:$false
```

> *Best Practice: Schema Admins must be empty at all times except during planned schema modifications. Members are only added temporarily and removed immediately after.*

3.5 Account Delegation Protection

The Administrator account was protected against Kerberos delegation attacks:

```
Set-ADUser -Identity 'Administrator' -AccountNotDelegated $true
```

Result: Prevents attackers from using delegation to impersonate the Administrator account.

3.6 NTLMv1 Disabled

NTLMv1 is a legacy and insecure authentication protocol. It was disabled via both registry and GPO:

```
Set-ItemProperty -Path 'HKLM:\SYSTEM\CurrentControlSet\Control\Lsa' -Name
'LmCompatibilityLevel' -Value 5
```

```
Set-GPRegistryValue -Name 'Default Domain Controllers Policy' -Key
'HKLM\SYSTEM\CurrentControlSet\Control\Lsa' -ValueName 'LmCompatibilityLevel' -
Type DWord -Value 5
```

LmCompatibilityLevel 5 = Only NTLMv2 responses are sent. NTLMv1 and LM are refused.

3.7 Audit Policy

Comprehensive audit policy was configured to capture all security-relevant events:

Audit Category	Setting
Credential Validation	Success and Failure
User Account Management	Success and Failure
Security Group Management	Success and Failure
Logon Events	Success and Failure
Logoff Events	Success
Sensitive Privilege Use	Success and Failure
Audit Policy Change	Success and Failure
Process Creation (4688)	Success
Directory Service Changes	Success and Failure

3.8 AD Backup

Windows Server Backup was installed and a system state backup was configured:

```
Install-WindowsFeature -Name Windows-Server-Backup
```

```
# Create VHD for backup storage
diskpart /s backup_script.txt  # Creates 30GB VHD mounted as E:
```

```
wbadmin start systemstatebackup -backupTarget:E: -quiet
```

Result: System state backup completed successfully, covering AD database, SYSVOL, and registry.

3.9 AES Encryption

Legacy RC4 Kerberos encryption was replaced with modern AES encryption:

```
# Enable AES for all user accounts
Get-ADUser -Filter {Enabled -eq $true} | Set-ADUser -KerberosEncryptionType
AES128,AES256
```

```
# Enable AES for krbtgt account
Set-ADUser -Identity krbtgt -KerberosEncryptionType AES128,AES256
```

Result: All Kerberos tickets now use AES256 encryption, eliminating RC4 downgrade attack vectors.

4. Phase 3 - LAPS Implementation

Windows LAPS (Local Administrator Password Solution) is built into Windows Server 2025. It automatically manages and rotates local administrator passwords on domain-joined computers, eliminating the risk of password reuse attacks.

4.1 LAPS Schema Extension

AD Schema was extended with LAPS attributes:

```
# Add Schema Admins temporarily for schema modification
Add-ADGroupMember -Identity 'Schema Admins' -Members 'SecAdmin'
```

```
# Extend schema with LAPS attributes
Update-LapsADSchema -Verbose
```

Schema attributes added:

- ms-LAPS-Password
- ms-LAPS-PasswordExpirationTime
- ms-LAPS-EncryptedPassword
- ms-LAPS-EncryptedPasswordHistory
- ms-LAPS-EncryptedDSRMPassword

```
# Remove from Schema Admins immediately after
Remove-ADGroupMember -Identity 'Schema Admins' -Members 'SecAdmin' -
Confirm:$false
```

4.2 LAPS Computer Permissions

```
Set-LapsADComputerSelfPermission -Identity 'DC=ADForest,DC=local'
```

Result: Computers can now update their own LAPS password attribute in AD.

4.3 LAPS GPO Configuration

```
New-GPO -Name 'LAPS Policy' | New-GPLink -Target 'DC=ADForest,DC=local'
```

```
# Backup passwords to Active Directory
```

```
Set-GPRegistryValue -Name 'LAPS Policy' -Key
'HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\LAPS' -ValueName
'BackupDirectory' -Type DWord -Value 2
```

```
# Password age 30 days, minimum length 16 characters
Set-GPRegistryValue -Name 'LAPS Policy' -Key
'HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\LAPS' -ValueName
'PasswordAgeDays' -Type DWord -Value 30
Set-GPRegistryValue -Name 'LAPS Policy' -Key
'HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\LAPS' -ValueName
'PasswordLength' -Type DWord -Value 16
```

> *Impact: A-LAPS-Not-Installed finding resolved. PingCastle score reduced by 15 points.*

5. Phase 4 - Privileged Account Management

5.1 SecAdmin Account Creation

A dedicated administrative account was created following the principle of least privilege. The built-in Administrator account (RID-500) is a well-known attack target - creating a separate admin account reduces this risk:

```
New-ADUser -Name 'SecAdmin' -SamAccountName 'SecAdmin' -UserPrincipalName
'SecAdmin@ADForest.local' -AccountPassword (ConvertTo-SecureString
'SecureP@ss123!' -AsPlainText -Force) -Enabled $true -PasswordNeverExpires
$false
```

```
Add-ADGroupMember -Identity 'Domain Admins' -Members 'SecAdmin'
```

```
# Mark as sensitive - cannot be delegated
Set-ADUser -Identity SecAdmin -AccountNotDelegated $true
```

5.2 BreakGlass Account (Emergency Recovery)

The built-in Administrator account was renamed to BreakGlass and disabled. This follows defence-in-depth principles - attackers expect 'Administrator' but find 'BreakGlass' disabled:

```
# Rename Administrator to BreakGlass
Rename-ADObject -Identity (Get-ADUser Administrator).DistinguishedName -NewName
'BreakGlass'
```

```
# Disable the account
Disable-ADAccount -Identity 'CN=BreakGlass,CN=Users,DC=ADForest,DC=local'
```

```
# Set complex emergency password
Set-ADAccountPassword -Identity 'CN=BreakGlass,CN=Users,DC=ADForest,DC=local' -
NewPassword (ConvertTo-SecureString 'Xk9#mP2$vL5@nQ8!' -AsPlainText -Force) -
Reset
```

Account	Purpose	Status	Usage
SecAdmin	Daily administration	Enabled	All routine admin tasks
BreakGlass (was Administrator)	Emergency recovery only	Disabled	Only when SecAdmin fails

> *Security Principles: Least Privilege, Defence in Depth, Security by Obscurity. The BreakGlass account password is stored securely offline.*

6. Phase 5 - Splunk SIEM Integration

Splunk Enterprise 10.2 was deployed as the SIEM solution. Despite being the free version (500MB/day ingestion limit), it provides full SIEM functionality for the homelab environment.

6.1 Splunk Configuration

Windows Event Log collection was configured via inputs.conf (GUI editing restricted in free version):

```
[WinEventLog://Security]
index = wineventlog
disabled = false
start_from = oldest
current_only = 1
renderXml = false
```

```
[WinEventLog://System]
index = wineventlog
disabled = false
current_only = 1
```

```
[WinEventLog://Application]
index = wineventlog
disabled = false
current_only = 1
```

```
[WinEventLog://Microsoft-Windows-Sysmon/Operational]
index = wineventlog
disabled = false
current_only = 1
renderXml = true
whitelist = 1,3,8,10,11,12,13,22
```

6.2 Sysmon Integration

Sysmon (System Monitor) v15.15 was installed and integrated with Splunk for deep endpoint visibility. Key challenge: Splunk returned errorCode=5 (Access Denied) when accessing Sysmon logs.

Resolution: Splunk service was configured to run as LocalSystem:

```
sc.exe config Splunkd obj= 'LocalSystem'
```

Splunk Add-on for Sysmon (TA-microsoft-sysmon v5.0.0) was installed to enable proper field extraction and sourcetype recognition.

6.3 Data Collection Results

Sourcetype	Daily Volume	Events
WinEventLog:Security	~176 MB	Failed logons, privilege use, group changes
xmlwineventlog (Sysmon)	~76 MB filtered	Process creation, network connections, registry
WinEventLog:System	~0.17 MB	System events, service starts/stops
WinEventLog:Application	~0.10 MB	Application events

> *Total daily ingestion: ~253MB - well within the 500MB free version limit. Sysmon filtered to critical event IDs: 1, 3, 8, 10, 11, 12, 13, 22.*

6.4 Key Security Searches

Search Purpose	SPL Query
Failed Logon Attempts	index=wineventlog EventCode=4625 | stats count by Account_Name | sort -count
Top Event Codes	index=wineventlog | stats count by EventCode | sort -count | head 10
Sysmon Process Creation	index=wineventlog sourcetype=xmlwineventlog | stats count by Image | sort -count | head 10
Logon Activity	index=wineventlog EventCode=4624 | stats count by Account_Name | sort -count

6.5 Splunk Dashboards Created

- AD Security Overview - Top Event Codes bar chart
- FailedLogonMonitor - Failed logons by account
- SysmonProcessMonitor - Top processes from Sysmon
- LogonActivityMonitor - Successful logon tracking

7. Phase 6 - BloodHound CE Attack Path Analysis

BloodHound Community Edition was deployed to visualize Active Directory attack paths - a critical tool for both offensive security (red team) and defensive security (blue team) operations.

7.1 Infrastructure

Component	Details
Platform	WSL2 Ubuntu 24.04 LTS on Windows Server 2025
Container Runtime	Docker Engine 29.3.0
BloodHound Version	Latest (SpecterOps)
Database	Neo4j 4.4.42 + PostgreSQL 16
Access URL	http://127.0.0.1:8080
Collector	SharpHound v2.10.0

7.2 Deployment Process

Key challenge: Docker Desktop does not support Windows Server. Solution: WSL2 with Docker Engine on Ubuntu.

```
# Install WSL2 and Ubuntu
wsl.exe --install
```

```
# Install Docker Engine on Ubuntu
sudo apt-get install -y docker-ce docker-ce-cli containerd.io docker-compose-plugin
```

```
# Deploy BloodHound CE
wget -O docker-compose.yml 'https://raw.githubusercontent.com/SpecterOps/BloodHound/main/examples/docker-compose/docker-compose.yml'
docker compose up -d
```

7.3 SharpHound Data Collection

```
# Disable Defender temporarily
Set-MpPreference -DisableRealtimeMonitoring $true
```

```
# Run SharpHound collection
.\SharpHound.exe -c All --domain ADForest.local
```

Collection result: 328 AD objects enumerated including users, groups, computers, GPOs, ACLs, and trust relationships.

7.4 Saved BloodHound Queries

Query Name	Cypher Query	Purpose
Domain Admin Members	MATCH (u)-[:MemberOf]->(g:Group {name:'DOMAIN ADMINS@ADFOREST.LOCAL'}) RETURN u,g	List all DA members
DCSync Rights Check	MATCH p=(n)-[:DCSync]->(d:Domain) RETURN p	Find DCSync privileges
Kerberoastable Accounts	MATCH (u:User {hasspn:true}) RETURN u	Find SPN accounts
Shortest Path to DA	PATHFINDING: Any -> Domain Admins	Attack path visualization

> *These queries are saved in BloodHound CE for reuse across future assessments and demonstrate proficiency in Cypher query language.*

8. Challenges & Resolutions

Challenge	Root Cause	Resolution
Splunk errorCode=5 for Sysmon	Splunk service lacked permission to read Sysmon event log	Changed Splunk service to run as LocalSystem via sc.exe config
Sysmon Add-on not loading	Triple-nested folder structure after extraction	Used robocopy to copy correct inner folder to Splunk apps directory
Docker Desktop on Windows Server	Docker Desktop requires Windows 10/11 desktop OS	Installed WSL2 + Ubuntu + Docker Engine as alternative
BloodHound CLI 404 error	v8.7.0 does not include Linux CLI binary	Used docker-compose method (official recommended approach)
Schema update access denied	Schema Admin group membership requires new login session	Restarted Windows Server to refresh Kerberos token
PingCastle score increased after fixes	SecAdmin left in Schema Admins after LAPS update	Removed SecAdmin from Schema Admins - best practice
Splunk Smart Mode hiding results	Stats queries show in Statistics tab not Events tab	Clicked Statistics tab to view results
SharpHound blocked by Defender	Windows Defender flags SharpHound as security tool	Temporarily disabled real-time monitoring during download

9. Planned Enhancements

9.1 TopTon Security Gateway (In Progress)

A TopTon mini PC (Intel N150, 33GB DDR5) is being configured as an inline security gateway:

Interface	Role
ETH0	WAN - Incoming internet cable
ETH1	LAN - WiFi router (home network)
ETH2	Homelab - Windows Server 2025
ETH3	Management/spare

Software stack:

- Rocky Linux 9 - Base OS
- Suricata - Inline IPS (active threat blocking)
- Zeek - Network traffic analysis and logging
- OpenVPN - Secure remote access

9.2 Additional Planned Items

- BadBlood - Realistic AD test data population
- Network architecture diagram (draw.io)
- Wazuh SIEM - Open source alternative/complement to Splunk
- MITRE ATT&CK framework mapping
- Incident response playbook
- Attack simulation and detection validation

10. Skills Demonstrated

Skill Area	Tools/Technologies	Level
Active Directory Administration	Windows Server 2025, PowerShell, ADUC	Proficient
Security Assessment	PingCastle, BloodHound CE, SharpHound	Proficient
SIEM Administration	Splunk Enterprise, SPL queries, Dashboards	Proficient
Endpoint Detection	Sysmon, Splunk Add-on for Sysmon	Proficient
Identity Management	LAPS, GPO, Privileged Account Management	Proficient
Containerisation	Docker Engine, WSL2, docker-compose	Competent
Linux Administration	Ubuntu, Rocky Linux, bash	Competent
Network Security	Suricata, Zeek, TAP monitoring	In Progress
Scripting	PowerShell, Bash	Proficient
Documentation	GitHub, Portfolio writing	Proficient

END OF PORTFOLIO DOCUMENT

Document generated for GitHub Portfolio

Arturs Kaufmanis | 2026